

BinX Tech • Engineering

Week 7 — Day 3

RBAC & Ownership Testing

Cardiac Patient Monitoring System

PREPARED BY

Mithgal Alhrene

.NET Internship Program

DOCUMENT FOCUS

Postman Evidence & API Authorization Testing

Sprint 2 — Authentication & RBAC

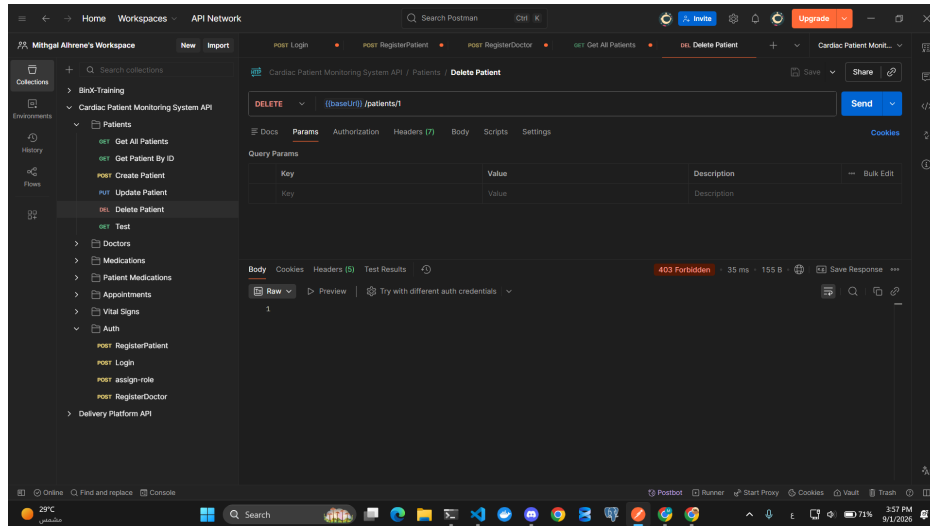
LAB SCOPE

Hands-on validation of authentication, role-based access control (RBAC), and resource ownership behavior in the Cardiac Patient Monitoring System API using Postman.

3. RBAC — Protected Patient Operations

The following evidence shows authorization enforcement on patient operations. The DELETE request was rejected with 403 Forbidden, demonstrating that the current authorization context is not permitted to perform the operation.

Evidence 02 — Patient Delete Authorization

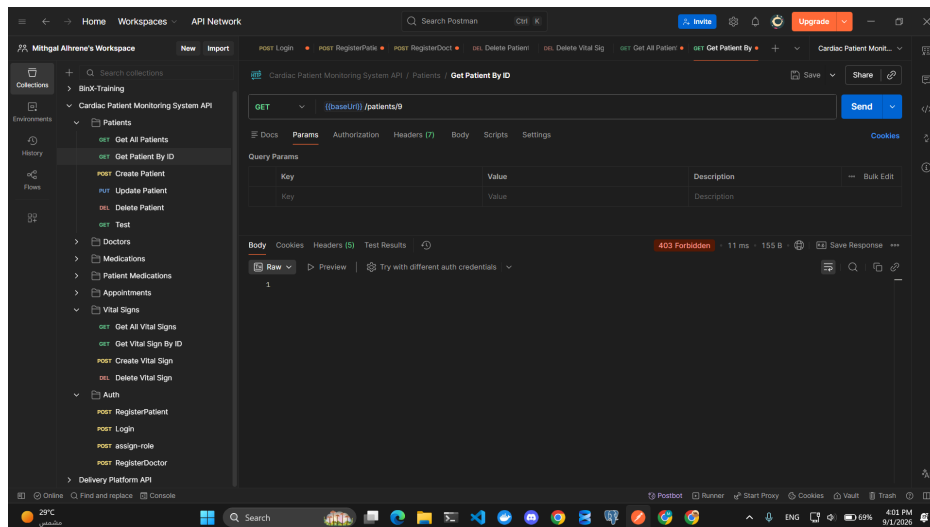


DELETE /patients/1 → 403 Forbidden

4. Ownership / Specific Record Access

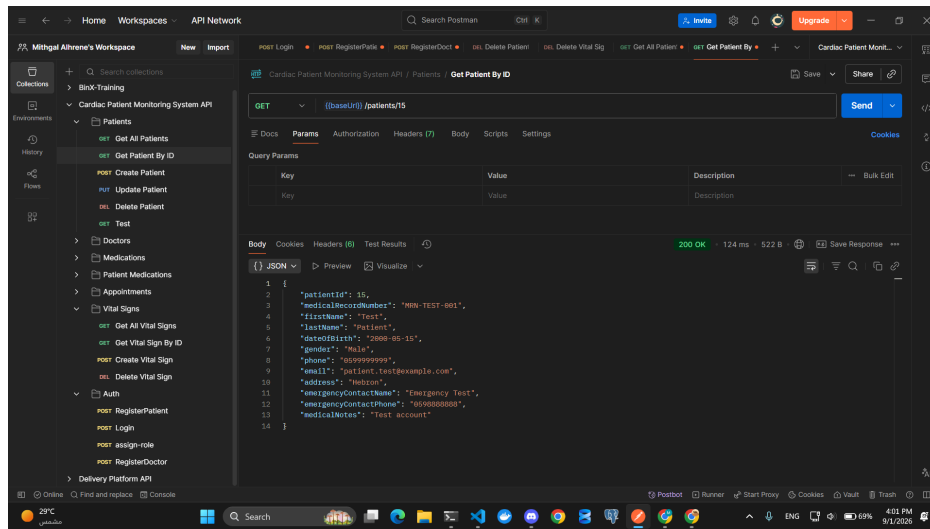
A specific patient lookup was tested under two authorization contexts. One request to a patient ID returned 403 Forbidden, while a permitted lookup of Patient ID 15 returned 200 OK with the patient record.

Evidence 03 — Rejected Patient Record Access



GET /patients/9 → 403 Forbidden

Evidence 04 — Authorized Patient Record Access

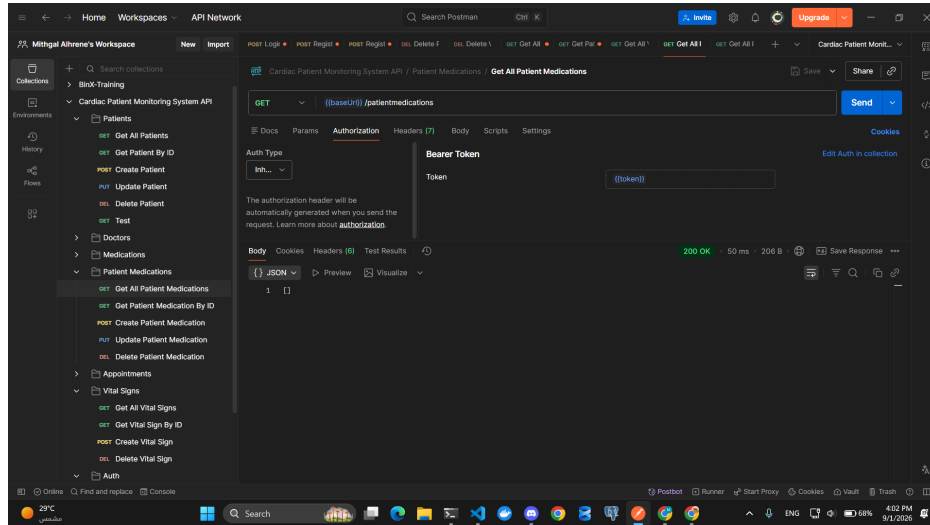


GET /patients/15 → 200 OK • Patient record returned

5. Authenticated Access to Protected Collections

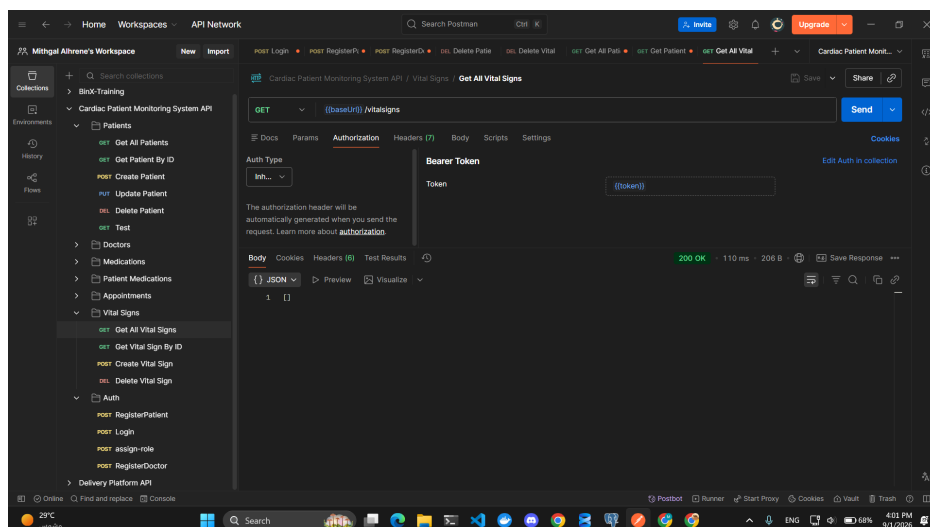
The captured collection requests returned 200 OK while using the configured Bearer Token authorization. Both responses were empty arrays, confirming that the endpoints were reachable and that no records were returned at the moment of testing.

Evidence 05 — Patient Medications



GET /patientmedications → 200 OK • []

Evidence 06 — Vital Signs

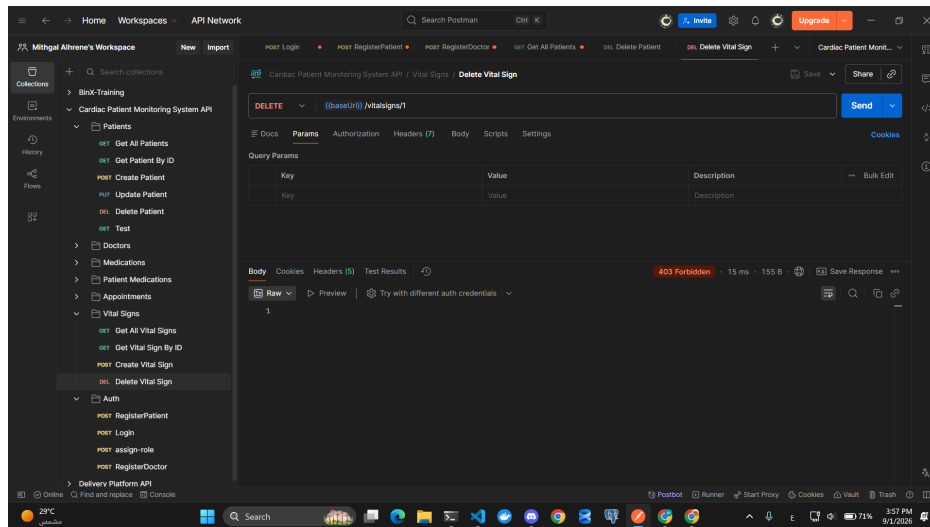


GET /vitalsigns → 200 OK • []

6. Additional Authorization Check

The final captured request shows another protected Vital Signs operation being rejected with 403 Forbidden. This provides an additional negative authorization result for the session.

Evidence 07 — Vital Sign Delete Authorization



DELETE /vitalsigns/1 → 403 Forbidden

7. Evidence Summary

Request	Result	Observed Behavior
POST /auth/login	200 OK	Patient authentication succeeded and a JWT was returned.
DELETE /patients/1	403	Protected delete operation was rejected.
GET /patients/9	403	Specific patient access was rejected.
GET /patients/15	200 OK	Authorized patient record was returned.
GET /patientmedications	200 OK	Endpoint reachable; response was [].
GET /vitalsigns	200 OK	Endpoint reachable; response was [].
DELETE /vitalsigns/1	403	Protected delete operation was rejected.

8. Conclusion

The captured Postman evidence demonstrates the core Week 7 Day 3 security-testing behavior: successful JWT authentication, successful access where permitted, and 403 Forbidden responses for protected operations that the current authorization context cannot perform. The evidence is presented as an execution record of the supplied screenshots.

COMPLETION NOTE

This report intentionally documents the tests that were actually captured in the screenshots rather than expanding the scope with additional unexecuted requests.